

Comprehensive Security & Compliance Architecture

Sistem STELA (Expertise Appointment Letter System)

Dokumen Resmi Arsitektur Solusi | Diterbitkan: 30 August 2026

1. Ringkasan Eksekutif (Executive Summary)

Di era transformasi digital saat ini, perlindungan aset informasi dan privasi data merupakan pondasi utama dari setiap operasional bisnis. Dokumen ini menyajikan analisis menyeluruh tentang arsitektur keamanan yang tertanam di dalam sistem **STELA**.

Visi utama kami adalah membangun *sistem yang secara proaktif melindungi dirinya sendiri* dari ancaman siber modern. STELA dikembangkan dengan komitmen kuat terhadap prinsip **CIA Triad** (*Confidentiality, Integrity, Availability*) guna memastikan bahwa data operasional klien tetap rahasia, transaksi bisnis tetap otentik, dan sistem selalu tersedia saat dibutuhkan.

2. Arsitektur Keamanan Lapis Ganda (Defense in Depth)

STELA tidak mengandalkan satu dinding pertahanan tunggal. Sebaliknya, kami mengadopsi filosofi **Defense in Depth**—sebuah strategi keamanan standar militer dan perbankan di mana beberapa lapisan perlindungan independen ditempatkan di seluruh arsitektur sistem.

Alur Pertahanan Transaksional:

- Perimeter Filter:** Permintaan masuk diseleksi oleh Firewall khusus sebelum menyentuh aplikasi.
- Identity Gateway:** Verifikasi identitas dan hak akses secara ketat untuk setiap permintaan.
- Payload Inspection:** Pembersihan otomatis terhadap data yang masuk dari anomali.
- Database Isolation:** Interaksi dengan basis data dilakukan melalui jalur parameter tertutup.

3. Detail Lapisan Keamanan Aplikasi (Pilar Utama)

3.1. Manajemen Identitas & Hak Akses (IAM)

Autentikasi Kuat & Enkripsi Kredensial

Sistem tidak pernah menyimpan kata sandi pengguna dalam format yang dapat dibaca. Kami menggunakan algoritma kriptografi *hashing* satu arah standar industri (*Bcrypt*). Hal ini mengeliminasi risiko kebocoran kata sandi bahkan jika basis data diakses oleh pihak yang tidak berwenang.

Pengendalian Akses Berbasis Peran (RBAC)

Otorisasi dilakukan secara granular (mendetail). Seorang pengguna hanya diberikan akses minimum yang diperlukan untuk menyelesaikan tugasnya (*Principle of Least Privilege*). Akses ke modul sensitif seperti persetujuan dan penghapusan data secara otomatis divalidasi silang oleh mesin kontrol akses.

Manajemen Sesi Otomatis

Sesi login dilindungi dengan mekanisme siklus hidup otomatis (*idle timeout*) dan rotasi identifikasi sesi. Ini secara signifikan mengurangi risiko pembajakan sesi (*Session Hijacking*) apabila pengguna lupa keluar dari perangkat publik.

3.2. Pertahanan Perimeter & Lalu Lintas (Perimeter Defense)

Integrasi Web Application Firewall (WAF)

STELA dilengkapi dengan lapisan WAF internal yang beroperasi secara seketika (*real-time*). WAF ini dirancang untuk mendeteksi dan memblokir pola permintaan yang mencurigakan (seperti upaya penyusupan skrip atau manipulasi jalur berkas) sebelum mereka mencapai logika inti aplikasi.

Mitigasi Denial of Service & Anti-Abuse

Untuk menjaga ketersediaan layanan (*Availability*), sistem dilengkapi dengan fitur *Rate Limiting*. Fitur ini membatasi jumlah permintaan berlebihan dari satu sumber dalam waktu singkat, efektif menggagalkan serangan *Brute Force* dan mencegah *server downtime* akibat lonjakan trafik buatan (DDoS skala kecil).

3.3. Integritas Data & Proteksi Formulir (Data Integrity)

Pengamanan Transaksi Formulir (Anti-CSRF)

Setiap transaksi elektronik dalam STELA (seperti penyimpanan atau pengubahan data) dilindungi oleh *Cross-Site Request Forgery (CSRF) Tokens*. Mekanisme ini menjamin bahwa perintah yang diterima sistem benar-benar dikirim secara sadar oleh pengguna yang sah, bukan oleh situs pihak ketiga yang berniat jahat.

Proteksi Injeksi Berlapis (SQLi & XSS Prevention)

Semua data yang masuk dan keluar dari sistem melewati proses sterilisasi. Untuk mencegah *SQL Injection*, sistem menggunakan pendekatan pemisahan tipe data (*Type Casting*) dan Kueri Terstruktur. Sementara itu, untuk mencegah serangan *Cross-Site Scripting (XSS)*, setiap data yang dirender ke layar pengguna dinetralkan, sehingga skrip berbahaya akan otomatis lumpuh menjadi teks biasa.

3.4. Keamanan Infrastruktur & Manajemen Berkas

Pemisahan Rahasia Lingkungan (Environment Segregation)

Kami memisahkan secara fisik antara kode sumber aplikasi dan variabel rahasia bisnis (seperti kunci enkripsi, token API, dan kata sandi basis data). Kredensial ini disimpan secara terisolasi di tingkat lingkungan *server*, mencegah kebocoran informasi yang tidak disengaja.

Sistem Karantina Unggahan Dokumen

Mengingat STELA memproses banyak dokumen klien, fasilitas unggahan berkas (*file upload*) dilengkapi dengan mekanisme Isolasi Eksekusi. Direktori penyimpanan berkas diubah fungsinya menjadi "zona mati" tempat di mana sistem web menolak keras segala bentuk eksekusi skrip, sehingga melumpuhkan ancaman *malware* yang menyamar sebagai dokumen gambar atau PDF.

4. Pemantauan & Auditabilitas (Monitoring)

Untuk mendukung transparansi dan investigasi bisnis, STELA menyediakan mekanisme pemantauan yang sangat tertutup:

- **Secure Error Logging:** Dalam lingkungan produksi, segala bentuk kerusakan teknis atau percobaan peretasan disembunyikan sepenuhnya dari layar pengunjung untuk mencegah pembocoran arsitektur (*Information Disclosure*). Namun, sistem secara diam-diam mencatat aktivitas anomali ini ke dalam berkas log terenkripsi internal yang hanya dapat diakses oleh tim teknis yang berwenang.

5. Kepatuhan terhadap Standar Industri (Compliance)

Kami menyadari bahwa kepatuhan (*Compliance*) adalah landasan kepercayaan bisnis. Oleh karena itu, rekayasa keamanan STELA diselaraskan dengan kerangka kerja pedoman global **OWASP (Open Worldwide Application Security Project) Top 10**.

Selain itu, seluruh pustaka perangkat lunak pihak ketiga (*dependencies*) yang digunakan dalam ekosistem STELA menjalani proses audit berkala. Kami secara proaktif menambal (*patch*) komponen eksternal untuk memastikan sistem bebas dari kerentanan publik (CVE) yang diketahui.

6. Kesimpulan

Sistem STELA tidak sekadar dirancang untuk mengelola surat keputusan dan data kepegawaian, tetapi dirancang sebagai benteng digital yang tangguh. Melalui penerapan arsitektur *Defense in Depth*, otorisasi berbasis peran yang ketat, serta pengawasan berstandar industri, STELA menjamin **Kelangsungan Bisnis (Business Continuity)** dan **Keandalan (Reliability)** jangka panjang bagi operasional organisasi Anda.